

# **MOBILE DEVICE VULNERABILITY MANAGEMENT MINI REPORT**

## **EXECUTIVE SUMMARY**

The Security Operations Center (SOC) team at Cyberinfiniti Ltd has identified three actively exploited Android vulnerabilities-CVE-2023-26083, CVE-2021-29256, and CVE-2023-2136-that impact GPU kernel drivers and the Chrome browser, enabling information disclosure, privilege escalation, and sandbox escape. With 40% of the organisation's 500 Android devices outdated by at least one year and 10% outdated by two years, the absence of a Mobile Device Management (MDM) solution significantly increases exposure to these threats. Unpatched devices present a high risk of data breaches, regulatory non-compliance, and operational disruption, underscoring the urgent need for immediate patching, centralised update management, and enhanced monitoring to mitigate exploitation.

## **1. Introduction & Objectives**

Cyberinfiniti Ltd currently manages a fleet of 500 Android devices, with a significant portion operating on outdated software-40% lagging behind by at least one year and 10% by two years. This lack of timely updates, compounded by the absence of a Mobile Device Management (MDM) solution, has created a critical security gap. Recent discoveries of actively exploited vulnerabilities, including CVE-2023-26083, CVE-2021-29256, and CVE-2023-2136, highlight the urgency of addressing these risks. These flaws affect GPU kernel drivers and the Chrome browser, enabling attackers to bypass protections through information disclosure, privilege escalation, and sandbox escape.

The objective of this report is to assess the impact of these vulnerabilities on the organisation's outdated devices, evaluate the potential threats posed by unpatched systems, and outline actionable recommendations to mitigate exposure. By understanding the severity of these risks and implementing effective security measures, the organisation can strengthen its resilience against exploitation, safeguard sensitive data, and ensure compliance with industry standards.

## **2. Core Investigation Requirements**

To effectively assess and mitigate the risks posed by outdated Android devices and the identified vulnerabilities, the following investigation requirements have been established:

**Vulnerability Analysis:** Research and document the technical details, severity, and exploitation methods of CVE-2023-26083, CVE-2021-29256, and CVE-2023-2136. Evaluate how these vulnerabilities impact GPU kernel drivers and Chrome.

**Device Risk Assessment:** Categorise the organisation's Android devices based on update status (current, one year outdated, two years outdated). Assess the likelihood of exploitation across these categories.

**Threat Implications:** Identify potential consequences of exploitation, including unauthorised access, data exfiltration, regulatory non-compliance, and operational disruption. Consider the broader impact of lacking MDM.

**Mitigation Strategy Development:** Recommend immediate actions to reduce exposure, including patch deployment, device prioritisation, and interim security controls.

## **PART 1 - Understanding the Risk**

### 3.1 CVE-2023-26083 - Arm Mali GPU Kernel Driver

**Overview:** CVE-2023-26083 is a vulnerability in the Arm Mali GPU kernel driver that allows non-privileged applications to perform GPU operations which inadvertently expose sensitive kernel metadata. This flaw undermines the separation between user space and kernel space, enabling attackers to gain insights into the operating system's internal structures. By leaking kernel memory addresses and metadata, adversaries can bypass protections such as Address Space Layout Randomisation (ASLR), making subsequent attacks more effective.

**Impact:** Exploitation enables attackers to extract kernel memory addresses and metadata, weakening confidentiality and providing adversaries with a detailed map of the kernel's internal layout that can be reused across multiple attack campaigns.

**Severity:** High. The CVSS base score may appear moderate, but real-world severity is elevated due to confirmed active exploitation. Attack complexity is low, requiring no elevated privileges and no user interaction.

#### Risks if Unattended:

- **Data Exposure:** Sensitive kernel data could be continuously leaked, providing attackers with valuable intelligence about system defences and memory layout.
- **Chained Exploits:** This vulnerability is often leveraged as part of a chain, enabling attackers to achieve full device compromise and persistent root access.
- **Persistence Risk:** Once attackers gain kernel-level access, they can install rootkits, disable security updates, and maintain covert access to corporate data.
- **Operational Impact:** Exploitation could lead to unauthorised access to sensitive business information, disruption of operations, reputational damage, and financial loss.

### 3.2 CVE-2021-29256 - Arm Mali GPU Kernel Driver (Use-After-Free)

**Overview:** CVE-2021-29256 is a high-severity vulnerability in the Arm Mali GPU Kernel Driver arising from a use-after-free memory flaw. Memory that has already been freed remains accessible to unprivileged users. Attackers can exploit this to read or manipulate freed memory containing sensitive kernel data structures, potentially escalating privileges to root. The Mali GPU driver is widely deployed across mobile, embedded, and IoT environments, making the scope of exposure significant.

#### Impact:

- **Information Disclosure:** Freed memory may contain kernel data structures and pointers, enabling attackers to bypass ASLR.
- **Privilege Escalation to Root:** Attackers can elevate privileges from standard user to root, gaining unrestricted control over the device.
- **System Integrity Risk:** Once the kernel is compromised, attackers can destabilise devices, create persistent backdoors, and interfere with normal operations.
- **Broad Target Scope:** Vulnerable drivers are used in smartphones, tablets, embedded systems, and IoT devices, expanding the attack surface.

**Severity:** High (NVD/Arm). Low attack complexity, no privileges required, no user interaction needed. The combination makes this vulnerability extremely dangerous in environments with outdated devices.

**Risks if Unattended:** Root compromise, data breach and exfiltration, chained exploits for persistence, operational disruption, and reputational damage.

### 3.3 CVE-2023-2136 - Skia Graphics Library (Google Chrome)

**Overview:** CVE-2023-2136 is an integer overflow vulnerability in the Skia graphics library, a core component used by Google Chrome for rendering graphics. This flaw causes memory corruption when arithmetic operations exceed the maximum storable value. A remote attacker who has compromised the renderer process can exploit this by delivering a crafted HTML page, enabling escape from Chrome's renderer sandbox. This significantly increases the attacker's ability to compromise the host system.

**Impact:**

- **Sandbox Escape:** Attackers can break out of Chrome's renderer sandbox, bypassing one of the browser's most important security barriers.
- **Remote Exploitation:** Malicious HTML or JavaScript can trigger the vulnerability simply by visiting a compromised website, making it highly scalable.
- **Privilege Escalation:** Once outside the sandbox, attackers can execute arbitrary code on the host system, install malware, or disable security tools.
- **Cross-Platform Exposure:** Chrome and Skia are deployed across Windows, macOS, Linux, and Android, affecting a broad range of devices.

**Severity:** High (Chromium). Low attack complexity, no privileges required, minimal user interaction (visiting a webpage). Confirmed active exploitation.

**Risks if Unattended:** Bypass of Chrome's security model; credential and data theft; drive-by exploitation at scale; malware infections and operational disruption.

### 3.4 Recommended Remediation (All CVEs)

- **Patch Deployment:** Update Mali GPU drivers and Chrome to the latest versions immediately. Ensure Android OS updates are applied promptly across all devices.
- **MDM Implementation:** Implement an MDM solution to enforce patch compliance, restrict app installations, and monitor device health.
- **Device Lifecycle Management:** Retire or replace devices older than two years that cannot receive security updates. Segment outdated devices from sensitive networks until patched or replaced.
- **Monitoring & Detection:** Deploy endpoint detection and response (EDR) tools to identify suspicious GPU driver activity, privilege escalation attempts, and unauthorised kernel access.
- **Policy & Awareness:** Establish a mobile security policy requiring timely updates and patch compliance. Educate staff on the risks of installing untrusted applications.

## PART 2 - Short-Term Action Plan

The following short-term plan is designed to immediately reduce the risk posed by the identified vulnerabilities while the organisation prepares for a longer-term mobile device management solution.

### 4.1 User Communication

- **Awareness Campaign:** Issue an internal memo or email to all employees explaining the urgency of updates, referencing the identified vulnerabilities and their potential impact.
- **Clear Messaging:** Provide simple, step-by-step instructions and emphasise that updates are mandatory for continued access to corporate resources.
- **Timeline:** Set a strict deadline for compliance (within two weeks) to ensure timely action.

### 4.2 Update Instructions

**Android OS Updates:** Navigate to Settings → System → Software Update. Download and install the latest available update.

**Google Chrome Updates:** Open Chrome → Settings → About Chrome. Ensure the browser is updated to the latest version.

**App Updates:** Use Google Play Store → My Apps & Games → Update All to ensure all apps are current.

### 4.3 Troubleshooting & Support

- **Helpdesk Support:** Establish a temporary support channel (email or hotline) for employees experiencing update issues.
- **FAQ Document:** Provide answers to common problems such as insufficient storage, battery requirements, or Wi-Fi connectivity.
- **Escalation Path:** Flag devices that cannot be updated for IT review and potential replacement.

### 4.4 Compliance Monitoring (Without MDM)

- **Manual Verification:** Require employees to submit screenshots showing their device's updated OS and Chrome version.
- **Spot Checks:** IT staff will conduct random checks during routine support interactions.
- **Access Controls:** Restrict access to sensitive corporate applications for devices that remain outdated.

### 4.5 Immediate Risk Reduction

- **Network Segmentation:** Place outdated devices on a separate VLAN with limited access until updates are confirmed.
- **Restrict App Installations:** Advise employees to avoid installing untrusted apps until updates are complete.

- **Safe Browsing Practices:** Remind users to avoid suspicious websites and links to reduce exposure to drive-by attacks.

## PART 3 - Long-Term Strategy

### 5.1 MDM Solution Comparison

Research into existing Mobile Device Management solutions has identified the following options suitable for the organisation's Android fleet:

| Solution             | Key Features                                                      | Benefits                                            | Drawbacks                                    | Cost/Device /Mo |
|----------------------|-------------------------------------------------------------------|-----------------------------------------------------|----------------------------------------------|-----------------|
| Microsoft Intune     | Cloud-based, Azure AD integration, cross-platform support         | Strong Microsoft ecosystem integration, scalable    | Requires Microsoft licensing, learning curve | \$6-\$8         |
| VMware Workspace ONE | Unified Endpoint Management, AI-driven automation, app management | Robust security, predictive analytics, BYOD support | Higher complexity, premium pricing           | \$8-\$12        |
| MobileIron (Ivanti)  | Mobile security focus, threat defence, compliance enforcement     | Strong Android support, granular policy control     | Limited non-mobile endpoint integration      | \$5-\$7         |
| Jamf                 | Specialised for iOS/macOS management                              | Best-in-class for Apple ecosystems                  | Limited Android support                      | \$6-\$10        |

**Recommendation:** For a mixed Android fleet, Microsoft Intune or VMware Workspace ONE are the most suitable options, balancing cost, scalability, and security capabilities.

### 5.2 Proposed Comprehensive Update Policy

A formal update policy is essential to ensure ongoing protection. The following guidelines are recommended:

- Standard updates must be installed within 30 days of release.
- Critical security patches (addressing actively exploited vulnerabilities) must be deployed within 7 days.
- Devices older than 3 years that can no longer receive vendor security updates should be phased out of the fleet.
- Non-compliant devices will be quarantined from corporate networks until updates are applied.
- Quarterly compliance audits will be conducted to verify adherence to the policy.

### 5.3 Future of Mobile Device Usage

Looking ahead, the organisation should consider the following trends and strategies to strengthen its mobile security posture:

- **AI-Driven Automation:** Predictive analytics and AI-driven threat detection will reduce IT workload and improve response times.
- **Zero Trust Architecture:** Implementing stronger identity and access controls will ensure that no device is trusted by default, regardless of location.
- **5G and Edge Computing:** Faster connectivity will enable real-time enterprise applications but will also require updated security frameworks.
- **BYOD Expansion:** As bring-your-own-device policies expand, organisations must balance flexibility with strict security enforcement to protect corporate data.

## **PART 4 - Team Discussion & Conclusion**

### **6.1 Summary of Findings**

Our analysis of the organisation's 500 Android devices reveals the following:

- 200 devices (40%) are outdated by at least one year.
- 50 devices (10%) are outdated by two years.
- No centralised MDM solution exists to enforce updates, monitor compliance, or restrict vulnerable devices.

#### **Vulnerability Risk Assessment:**

- CVE-2021-29256: Critical risk - enables root privilege escalation with low complexity.
- CVE-2023-26083: High risk - information disclosure enabling chained exploits and ASLR bypass.
- CVE-2023-2136: High risk - sandbox escape via crafted web content with cross-platform impact.

The operational impact of these vulnerabilities includes potential data breaches, regulatory non-compliance, reputational damage, and disruption of business operations.

### **6.2 Proposed Team Meeting Agenda**

To facilitate discussion and alignment, the following agenda is recommended for the team meeting:

1. Review vulnerability findings and device risk profile.
2. Present the short-term action plan and compliance timeline.
3. Discuss MDM solution options, features, and budget considerations.
4. Agree on the comprehensive update policy and device lifecycle management strategy.
5. Gather feedback from team members and adjust plans accordingly.

Following the meeting, all feedback will be documented and incorporated into the final implementation plan.

### 6.3 Conclusion

The vulnerabilities identified pose a significant and immediate risk to Cyberinfiniti Ltd, particularly given the high percentage of outdated devices within the fleet. The short-term action plan ensures immediate risk reduction through structured communication, mandatory updates, compliance monitoring, and temporary network controls. The long-term strategy focuses on sustainable solutions, including MDM adoption, a comprehensive update policy, device lifecycle management, and enhanced monitoring capabilities.

By implementing these measures, the organisation will significantly reduce its attack surface, improve its security posture, and establish a framework for ongoing mobile device security management. Following the team meeting, feedback will be incorporated to refine these plans and ensure alignment with organisational priorities and budget constraints.

---

*- End of Report -*